



Assessment Cover Sheet

Assessment Title	Group Project		
Assessment Type	Uncontrolled	Group	Not must-pass
Due Date	21/05/2026	Course Code	IT8515
Course Title	Cybersecurity Compliance and Regulations		
Internal Moderator's Name	Dr. Faheem Masoodi		
External Examiner's Name	Dr. James Eagan		

Instructions:

1. This cover sheet must be completed (section in blue below) and attached to your assessment before submission in hard copy/soft copy.
2. The time allowed for this assessment is 74 days.
3. This assessment carries 25% marks; assessing CILO 1, and CILO 2.
4. The materials allowed for use in this assessment are XXX, XXX, and XXX.
5. The **use of generative AI tools is strictly prohibited**.
6. References consulted (if any) must be properly acknowledged and cited.
7. The assessment has a total of 07 pages.

Learner ID		Date Submitted	24/5/2026
Learner Name	Abdulelah Slais, Abdulrahman Altairey, Khalid Alhariri, Abdullah Hoth		
Programme Code	IT8515		
Programme Title	Cybersecurity Compliance and Regulations		
Lecturer's Name	Mohamed Yasin		

By submitting this assessment for marking, I affirm that this assessment is my own work.

Learner Signature	Abdulelah Slais
-------------------	-----------------

Do not write beyond this line. For assessor use only.

Assessor's Name			
Marking Date		Maks Obtained	

Comments:

Table of Contents

- 1. Executive Summary..... 3
 - 1.1 Project Objectives and Scope 3
 - Key Findings 3
- 2. Organization and Sector Context..... 3
 - 2.1 Key Assumptions..... 3
- 3. Methodology and Lab Setup..... 4
- 4. Implementation Requirement Traceability 4
- 5. Eramba Implementation Evidence 5
 - 5.1 Student 1 - Asset and Risk Lead..... 5
 - 5.2 Student 2 - Policy and Control Lead..... 7
 - 5.3 Student 3 - Compliance and Privacy Lead..... 10
 - 5.4 Student 4 - Integration, Incident and Reporting Lead 12
 - 5.5 Additional Cross-Module Evidence..... 14
- 6. Analysis and Discussion 17
 - 6.1 Top Risk Interpretation 17
 - 6.2 Compliance and Privacy Interpretation 18
 - 6.3 Incident and Improvement Interpretation 18
- 7. Conclusion and Recommendations 18
 - Recommendations..... 18
- 8. Workload Contribution Table 18
- 9. References 19
- Appendix A - Evidence Index 19
- Appendix B - Final Readiness Checklist..... 20

1. Executive Summary

This report documents the design and implementation of a centralized Governance, Risk and Compliance (GRC) system in Eramba

for the Government Digital Services Authority in Eramba. The Authority provides services to citizens online, stores the citizen identities, holds employees' HR data, and runs infrastructures such as email and virtual server services. The current report is guided by IT8515 Eramba process in Labs 7 through 10 to form organizations, assets, risks, policies, internal controls, compliance mapping, privacy data, incidents, and improvement activities.

The current implementation project successfully completes all the core elements of Eramba that were identified in the project brief, such as organization definition, assets & risks management, policy management, internal controls, compliance management, data privacy management, incident management, dashboard, and risk treatment planning. The attached screenshots present evidence of the needed records and the traceability between assets, risks, internal controls, policies, compliance requirements, third parties, data flows, incidents, and improvement activities.

1.1 Project Objectives and Scope

The goal of this exercise will be to develop an end-to-end GRC solution for a Government Digital Services Authority, with the following in-scope components: creating business units, assets, risks, policies, controls, compliance mapping, privacy, incidents, treatments, projects, and dashboards. The GRC implementation will utilize NIST CSF 2.0 and a privacy/compliance package for the specific industry sector to showcase how governance, risk, compliance, data privacy, and incidents can be integrated into a single GRC solution.

Key Findings

- The primary initial risk exposure is unauthorized access to citizen information, which is countered using multifactor authentication, identity governance policy, and a related improvement initiative.
- Risks from ransomware and outages are controlled using backup/recovery measures, data resilience strategy, and improvements to recovery process.
- Risks of email phishing attacks are countered using email filtering control, email security policy, and a phishing protection improvement initiative.
- Compliance are covered using NIST CSF 2.0 standards and government/privacy regulations specific to the sector with requirements mapped to control, policy and risk.
- Privacy governance has been improved by identifying processing activities, data owner, DPO responsibility, processor roles, third parties, and GDPR fields for three privacy data assets.

2. Organization and Sector Context

The chosen sector is Government / Public Sector. The organization model chosen for analysis is a made-up Government Digital Services Authority offering citizens access via Internet to various government services, internal activities, and functions. This includes handling confidential information about citizens, information about authentication, information on employee HR, information on access logs, email services, information on documents management, and virtual servers infrastructure. Due to their confidential and public service nature, confidentiality, integrity, availability, and regulatory requirements have been the major drivers of classification.

2.1 Key Assumptions

- Personal information on citizens' identity and HR information of employees is sensitive information that requires adequate privacy and security measures.
- Citizen Services Department has possession of all citizen services-related information and data.
- The Human Resource Department has possession of all employee HR information and data.

- IT Operations Department manages government email services and virtual server infrastructure.
- This company utilizes external vendors for purposes of identity verification, cloud-based backups, and analytics on security monitoring.
- The Eramba solution is adopted as the central GRC repository for Risks, Controls, Policies, Compliance, Privacy, Incidents, and Projects.

3. Methodology and Lab Setup

Implementation was done in a secure laboratory environment using Eramba. An instance of Eramba using the browser was used to create and link entries in the Organization, Asset Management, Risk Management, Control Catalog, Compliance Management, Data Privacy, Security Operations, and Project Management modules. The process started following the class labs where Week 7 involved creating assets and risk, Week 8 involved policy management, Week 9 internal control management and compliance management, and finally, Week 10 for data privacy and incident response.

Implementation of the lab was performed using a browser-based Eramba instance on a secured project environment. The choice of NIST CSF 2.0 as the standard is due to its recognized framework for addressing cybersecurity in terms of identification, protection, detection, response, and recovery in case of any cyber risks. Additionally, a government/privacy compliance package was used since the chosen organization uses sensitive information related to citizens' identity, human resource information, and logs for services access.

Lab / Module	Implementation Purpose in This Project
Week 7 - Asset and Risk	Creation of business unit, asset, and liability driver; risk scoring model, risk appetite matrix, and asset risk register.
Week 8 - Policy Management	Creation of policies, definition of ownership, setting of publish flag configuration, and creation of review/evidence version.
Week 9 - Internal Control & Compliance	Creation of controls, audit, maintenance and compliance mapping for framework, policy, control, and risk.
Week 10 - Data Privacy and Incident Response	Creation of privacy data assets, processing activities, third parties, data flow, GDPR fields, incident stages, and incident response linkage.

4. Implementation Requirement Traceability

Project Requirement	Minimum	Implemented Evidence	Status
Business Units	3	Citizen Services Department, IT Operations Department, Human Resources Department	Completed
Assets	5, at least 2 data assets	5 key assets with 3 privacy-related data assets	Completed
Asset liabilities / classification drivers	3 categories/types	Confidentiality, Integrity, Availability, Legal / Regulatory	Completed
Risks	5 asset risks	5 risks associated with assets and rated	Completed
Policies	4 policies with reviews	Identity Governance, Data Resilience, Email Security, Incident Response	Completed
Internal Controls	4 controls with audit & maintenance plans	MFA, Backup and Recovery, Email Filtering, Incident Reporting	Completed
Compliance Packages	2 frameworks	NIST CSF 2.0 framework along with privacy/compliance packages	Completed
Compliance Requirements	5 mapped	Mapped NIST framework and other sector standards to controls, policies, risks	Completed
Privacy Data Assets	3	Citizen Records, HR Records, Citizen Service Access Logs	Completed
Data Flows	3	Identity proofing, cloud backup, service logs analysis	Completed
Third Parties	3	Identity Gateway, Cloud Backup Provider, Security Monitoring Analytics Provider	Completed

Incidents	4	Unauthorized access, ransomware, phishing, virtual server outage	Completed
Risk Treatment Plans	3	Access control, ransomware recovery, phishing protection projects	Completed
Dashboard Widgets	2	Asset-based risk matrix and current compliance status	Completed

5. Eramba Implementation Evidence

5.1 Student 1 - Asset and Risk Lead

Student 1 created the foundation for the GRC system by defining the organizational structure, classifying assets, configuring the risk calculation method, creating the risk appetite matrix, and building the asset risk register. This section proves the organization setup and risk management requirements.

Area	Implemented Items
Business Units	Citizen Services Department, IT Operations Department, Human Resources Department
Core Assets	Citizen Records Database, Employee HR Records System, Government Email System, Document Management System, Virtual Server Infrastructure
Classification Drivers	Confidentiality, Integrity, Availability, Legal / Regulatory
Risk Scoring	Single Matrix - Multiplication using likelihood and impact
Asset Risks	Unauthorized Access to Citizen Records, Ransomware in HR Records System, Phishing Through Government Email System, Loss of Official Documents, Service Outage in Virtual Server Infrastructure

Business Units

Processes

Business Units

+ Add Item

All items 3

Business Units With...

Views

+

Filter

1 Sort

Columns

☐	☐	Dynamic Status	Name	Processes	Business Unit Contact	Potential Liabilities	Asset Risks	Business Risks
☐	☐		Human Resources Department	0	System Group - View All	0	1	0
☐	☐		IT Operations Department	0	System Group - View All	0	2	0
☐	☐		Citizen Services Department	0	System Group - View All	0	2	0

Figure 1: Organization's business units configured in Eramba.

Relevance: The above figure shows that the organizational structure has been formed using number of three business units that are used for managing assets, risks, incidents, and flows.

AA

Liabilities

+ Add Item

All it... 4

Save as copy

Views

+

Filter

Sort

Columns

☐	Name	Liability Contact	Risk Magnifier	Assets	Asset Risks	Third Party Risks	Business Risks
☐	Legal / Regulatory	System Group - View A	10	Citizen Records Database	2	0	0
☐	Availability	System Group - View A	10	Government Email System	3	0	0
☐	Integrity	System Group - View A	10	Citizen Records Database	4	0	0
☐	Confidentiality	System Group - View A	10	Citizen Records Database	3	0	0

Figure 2: Asset liability and classification drivers configured in Eramba.

Relevance: This proves that confidentiality, integrity, availability, and legal/regulatory drivers were created and applied consistently to support risk scoring.

Assets

Dynamic Status Name Related Business Units Type Reviews Next Review Date GRC Contact Asset Reviewer Contact

☐	☐	Citizen Service Access L...	Citizen Services Department	Data Asset	2	2026-12-31	System Group - View A...	Citizen Service...
☐	☐	Virtual Server Infrastruct...	IT Operations Department	Hardware	2	2026-12-31	System Group - View A...	Infrastructure A...
☐	☐	Document Management ...	Citizen Services Department	Software	2	2026-12-31	System Group - View A...	Records Manag...
☐	☐	Government Email System	IT Operations Department	IT Service	2	2026-12-31	System Group - View A...	Email Systems ...
☐	☐	Employee HR Records Sy...	Human Resources Department	Data Asset	2	2026-12-31	System Group - View A...	Employee HR R...
☐	☐	Citizen Records Database	Citizen Services Department	Data Asset	2	2026-12-31	System Group - View A...	Citizen Service...

Assets

Next Review Date GRC Contact Asset Reviewer Contact Potential Liabilities Asset Risks Third Party Risks Data Asset Flow

2026-12-31	System Group - View A...	Citizen Services Mana...	Confidentiality Integrity			1
2026-12-31	System Group - View A...	Infrastructure Administ...	Integrity Availability	Service Outage in Virtual Servi...		
2026-12-31	System Group - View A...	Records Management C...	Integrity Availability Leg...	Loss of Official Documents		
2026-12-31	System Group - View A...	Email Systems Adminis...	Confidentiality Availability	Phishing Through Governmen...		
2026-12-31	System Group - View A...	Employee HR Records ...	Confidentiality Integrity	Ransomware in HR Records Sy...		1
2026-12-31	System Group - View A...	Citizen Services Mana...	Confidentiality Integrity	Unauthorized Access to Citi...	Privacy Exposure Through Ide...	1

Figure 3: Asset inventory showing critical systems, business units, owners, review dates, and potential liabilities.

Relevance: This evidence confirms that the project includes at least five assets, including data assets, and that each asset has governance ownership and review accountability.

Edit Action

Single Matrix - Addition **Single Matrix - Multiplication** No Matrix - Magerit Multiple Matrices - Multiplication

Enable ☒

Method Name: Single Matrix - Multiplication

Description: This method will multiply the classifications defined on the field below, for example if you define two classification types likelihood and impact they will be multiplied on each risk. In the case of Asset Risk Management, if the input asset has liabilities with a risk magnifier value different from zero they will be also included on the multiplication.
The formula is then: (multiplication of classifications) * (summation of asset liabilities), bare in mind if the summation of liabilities equals zero the second part of the equation is ignored to avoid a risk score of zero.

Settings: AFTER RE-SAVING A CALCULATION THE SYSTEM TAKES ANY AVAILABLE CLASSIFICATION FROM THE SELECTED TYPES BELOW AND RECALCULATE ALL RISKS.

Likelihood **Impact**

Select two Risk Classification criteria in order to calculate Risk Scores.

Close Save

Figure 4: Risk calculation method configured as Single Matrix - Multiplication.

Relevance: This proves that Eramba calculates risk scores using likelihood and impact classifications and supports a consistent risk register.



Figure 5: Dashboard asset-based risk matrix showing analysis and treatment stage risk positions.

Relevance: This validates the risk appetite matrix and demonstrates that risk treatment reduces several risks from higher analysis positions to lower residual positions.

Dynamic Status	Reviews	Name	Next Review Date	Related Assets	Risk Analysis Classification	Risk Analysis Score	Risk Treat
	2	Service Outage in Virtual ...	2026-12-31	Virtual Server Infrastructure	likelihood (Possible) impact (Major)	240 ● High	Mitigate
	2	Loss of Official Documents	2026-12-31	Document Management System	likelihood (Possible) impact (Moderate)	270 ● Moderate	Mitigate
	2	Phishing Through Govern...	2026-12-31	Government Email System	likelihood (Likely) impact (Moderate)	240 ● High	Mitigate
	2	Ransomware in HR Recor...	2026-12-31	Employee HR Records System	likelihood (Likely) impact (Major)	320 ● High	Mitigate
	2	Unauthorized Access to ...	2026-12-31	Citizen Records Database	likelihood (Likely) impact (Critical)	600 ● Severe	Mitigate

Figure 6: Asset risk register showing five risks linked to assets, scores, treatment, and residual scores.

Relevance: This proves the risk register requirement and shows that all risks were scored, assigned a treatment, and linked to assets.

Risk Treatment	Treatment Risk Exceptions	Treatment Internal Controls	Treatment Projects	Treatment Policies	Risk Treatment Classification	Risk Treatment Score
Mitigate		Incident Reporting and Escalation		Incident Response Policy	likelihood (Unlikely) impact (Moderate)	120 ● Moderate
Mitigate		Backup and Recovery Control		Data Resilience and Recovery Policy	likelihood (Unlikely) impact (Minor)	120 ● Tolerable
Mitigate		Email Filtering and Anti-Phishing	Email Phishing Protection Improvement	Email Security Policy	likelihood (Unlikely) impact (Moderate)	120 ● Moderate
Mitigate		Backup and Recovery Control	HR Ransomware Recovery Improvement	Data Resilience and Recovery Policy	likelihood (Unlikely) impact (Major)	360 ● Moderate
Mitigate		Multi-Factor Authentication Control	Citizen Access Control Improvement	Identity Governance and Privacy Policy	likelihood (Unlikely) impact (Major)	240 ● Moderate

Figure 7: Risk treatment view showing internal controls, policies, projects, and residual treatment classifications.

Relevance: This proves cross-module linkage between risks, controls, policies, and improvement projects, which is required for integrated GRC reporting.

5.2 Student 2 - Policy and Control Lead

Student 2 created the policy and control layer of the GRC system. Policies define governance expectations, while internal controls show the practical security activities used to treat risks. Audit and maintenance records were created so that each control has evidence of testing and ongoing operation.

Policy / Control Area	Implemented Items
Policies	Identity Governance and Privileged Access Policy; Data Resilience and Recovery Policy; Email Security Policy; Incident Response Policy
Internal Controls	Multi-Factor Authentication Control; Backup and Recovery Control; Email Filtering and Anti-Phishing Control; Incident Reporting and Escalation Control

Audit Evidence	Audit records created for the controls with methodology, success criteria, planned dates, and audit ownership.
Maintenance Evidence	Maintenance records created for controls with planned maintenance tasks and ownership.
Linkage	Policies and controls were linked to asset risks, compliance requirements, and data flows.

The screenshot shows the 'Policies' library interface. It includes a table with columns: Dynamic Status, Reviews, Name, Description, Version, Document Content, Published Date, Next Review Date, Policy Labels, and Document Type. Four policies are listed: Incident Response Policy, Email Security Policy, Data Resilience and Reco..., and Identity Governance and ... Each policy has a review count of 2 and a next review date of 2026-12-31.

Dynamic Status	Reviews	Name	Description	Version	Document Content	Published Date	Next Review Date	Policy Labels	Document Type
	2	Incident Response Policy	This policy defines how c...	1.0	Use Content	2026-05-23	2026-12-31		Policy
	2	Email Security Policy	This policy defines safe e...	1.0	Use Content	2026-05-23	2026-12-31		Policy
	2	Data Resilience and Reco...	This policy defines how c...	1.0	Use Content	2026-05-23	2026-12-31		Policy
	2	Identity Governance and ...	This policy defines how u...	1.0	Use Content	2026-05-23	2026-12-31		Policy

Figure 8: Policy library showing four published policies with review counts and next review dates.

Relevance: This proves that the minimum four-policy requirement was met and that policies were treated as active governance documents rather than simple text entries.

The screenshot shows the 'Policy Reviews' interface. It includes a table with columns: Dynamic Status, Policies, Planned Date, Actual Date, Description, Next Review Date, Document Type, Version, Document Content, and URL. Eight review records are listed, showing planned and actual review dates and document content.

Dynamic Status	Policies	Planned Date	Actual Date	Description	Next Review Date	Document Type	Version	Document Content	URL
	Incident Response Policy	2026-12-31			2026-12-31	Policy			
	Incident Response Policy	2026-05-23	2026-05-23	This Review was automat...	2026-12-31	Policy	1.0	Use Content	
	Email Security Policy	2026-12-31			2026-12-31	Policy			
	Email Security Policy	2026-05-23	2026-05-23	This Review was automat...	2026-12-31	Policy	1.0	Use Content	
	Data Resilience and Reco...	2026-12-31			2026-12-31	Policy			
	Data Resilience and Reco...	2026-05-23	2026-05-23	This Review was automat...	2026-12-31	Policy	1.0	Use Content	
	Identity Governance and ...	2026-12-31			2026-12-31	Policy			
	Identity Governance and ...	2026-05-23	2026-05-23	This Review was automat...	2026-12-31	Policy	1.0	Use Content	

Figure 9: Policy review records showing version and planned review evidence for the created policies.

Relevance: This demonstrates policy lifecycle management, version history, and future review scheduling as required in the policy management workflow.

The screenshot shows the 'Internal Controls' interface. It includes a table with columns: Dynamic Status, Audits, Maintenances, Issues, Name, Description, Control Operator Contact, and Security Policies. Four controls are listed: Incident Reporting and E..., Email Filtering and Anti-P..., Backup and Recovery Co..., and Multi-Factor Authenticati... Each control has associated audit, maintenance, and issue counts, a control operator contact, and a linked security policy.

Dynamic Status	Audits	Maintenances	Issues	Name	Description	Control Operator Contact	Security Policies
	2	2	0	Incident Reporting and E...	This control ensures that ...	Infrastructure Administ...	Incident Response Policy
	2	2	0	Email Filtering and Anti-P...	This control protects the ...	Email Systems Administ...	Email Security Policy
	2	2	0	Backup and Recovery Co...	This control ensures that ...	Infrastructure Administ...	Data Resilience and Recover...
	2	2	0	Multi-Factor Authenticati...	This control requires user...	Infrastructure Administ...	Identity Governance and Priv

Internal Controls

Audits

Issues

Maintenances

Internal Controls

+ Add Item

All items 4

Save as copy

Views

Filter 1 Sort Columns

		Security Policies	Risks	Third Party Risks	Business Continuities	Compliance Package
		Incident Response Policy	Service Outage in Virtual Service			Government Digital Services Cybersecurity Compliance Profile NIST Cybersecurity Framework 2.0
		Email Security Policy	Phishing Through Government			Government Digital Services Cybersecurity Compliance Profile NIST Cybersecurity Framework 2.0
		Data Resilience and Recovery	Ransomware in HR Records System			Government Digital Services Cybersecurity Compliance Profile NIST Cybersecurity Framework 2.0
		Identity Governance and Privilege Management	Unauthorized Access to Citizen	Privacy Exposure Through Identity		Government Digital Services Cybersecurity Compliance Profile Bahrain Personal Data Protection Compliance Profile NIST Cybersecurity Framework 2.0

Figure 10: Internal controls list showing four controls with audit counts, maintenance counts, related policies, and linked risks.

Relevance: This proves that controls are operational solutions connected to policies and risks, not standalone entries.

Internal Controls

Audits

Issues

Maintenances

Internal Control Audits

+ Add Item

Settings

All items 8

Save as copy

Views

Filter 1 Sort Columns

	Dynamic Status	Internal Control	Internal Control Status	Audit Methodology	Audit Success Criteria	Planned Start	Audit Owner	AI
☐	☐	Incident Reporting and E...	Production	The audit will review inci...	The audit passes if incide...	<input type="calendar"/> 2027-12-31	<input type="person"/> Infrastructure Administ...	
☐	☐	Incident Reporting and E...	Production	The audit will review inci...	The audit passes if incide...	<input type="calendar"/> 2026-12-31	<input type="person"/> Infrastructure Administ...	
☐	☐	Email Filtering and Anti-P...	Production	The audit will review ema...	The audit passes if phishi...	<input type="calendar"/> 2027-12-31	<input type="person"/> Email Systems Adminis...	
☐	☐	Email Filtering and Anti-P...	Production	The audit will review ema...	The audit passes if phishi...	<input type="calendar"/> 2026-12-31	<input type="person"/> Email Systems Adminis...	
☐	☐	Backup and Recovery Co...	Production	The audit will review bac...	The audit passes if back...	<input type="calendar"/> 2027-12-31	<input type="person"/> Infrastructure Administ...	
☐	☐	Backup and Recovery Co...	Production	The audit will review bac...	The audit passes if back...	<input type="calendar"/> 2026-12-31	<input type="person"/> Infrastructure Administ...	
☐	☐	Multi-Factor Authenticati...	Production	The audit will review whe...	The audit passes if MFA i...	<input type="calendar"/> 2027-12-31	<input type="person"/> Infrastructure Administ...	
☐	☐	Multi-Factor Authenticati...	Production	The audit will review whe...	The audit passes if MFA i...	<input type="calendar"/> 2026-12-31	<input type="person"/> Infrastructure Administ...	

Figure 11: Internal control audit records created for the implemented controls.

Relevance: This provides testing evidence for the controls and supports audit readiness by showing methodology, success criteria, dates, and ownership.

Internal Controls

Audits

Issues

Maintenances

Internal Controls Maintenances

+ Add Item

Settings

All Items 8

Views

+

Filter 1 Sort Columns

☐	Dynamic Status	Internal Control	Internal Control Status	Maintenance Task	Planned Start	Maintenance Start Date	Maintenance End Date
☐	☐	Incident Reporting and E...	Production	Incident response contac...	☐ 2027-12-31		
☐	☐	Incident Reporting and E...	Production	Incident response contac...	☐ 2026-12-31		
☐	☐	Email Filtering and Anti-P...	Production	Email filtering rules, anti-...	☐ 2027-12-31		
☐	☐	Email Filtering and Anti-P...	Production	Email filtering rules, anti-...	☐ 2026-12-31		
☐	☐	Backup and Recovery Co...	Production	Backup schedules, stora...	☐ 2027-12-31		
☐	☐	Backup and Recovery Co...	Production	Backup schedules, stora...	☐ 2026-12-31		
☐	☐	Multi-Factor Authenticati...	Production	The MFA configuration wi...	☐ 2027-12-31		
☐	☐	Multi-Factor Authenticati...	Production	The MFA configuration wi...	☐ 2026-12-31		

Figure 12: Internal control maintenance records showing planned maintenance activities for controls.

Relevance: This proves that controls are maintained over time and that Eramba is used to track ongoing control operation.

5.3 Student 3 - Compliance and Privacy Lead

Student 3 implemented the compliance and privacy requirements. NIST CSF 2.0 was imported as the main cybersecurity framework, and a sector-relevant compliance package was created for government digital services and privacy obligations. Privacy-focused data assets, processing activities, third parties, data flows, GDPR fields, and third-party risk evidence were also created.

Compliance / Privacy Area	Implemented Items
Frameworks	NIST CSF 2.0; Government Digital Services Cybersecurity Compliance Profile; Bahrain Personal Data Protection Compliance item
Mapped Requirements	Identity and access, backup/recovery, email/phishing, incident readiness, lawful processing/privacy
Privacy Data Assets	Citizen Records Database, Employee HR Records System, Citizen Service Access Logs
Third Parties	National Identity Verification Gateway, Secure Cloud Backup Provider, Security Monitoring Analytics Provider
Data Flows	Citizen Identity Verification Data Flow, Secure Cloud Backup Data Flow, Citizen Access Log Monitoring Data Flow
Third-Party Risk	Privacy Exposure Through Identity Verification Gateway

The screenshot shows the Eramba web application interface. The left sidebar contains navigation links: Dashboard, Program, Organization, Asset Management, Control Catalog, Risk Management, Compliance Management (selected), Security Operations, and Settings. The main content area is titled 'Compliance Package Items' and displays a table with 134 items. The table has columns: Chapter ID, Chapter Name, Chapter Description, Item ID, Item Name, Item Description, and Item Additional Information. The items are grouped by chapter, with 'GV' (Governance) and 'GV.OC' (Organizational Context) visible. A 'Filter' button is present in the top right of the table area.

Figure 13: NIST Cybersecurity Framework 2.0 compliance package imported with 134 requirement items.

Relevance: This proves the NIST CSF 2.0 import requirement and creates the main framework repository for compliance analysis.

The screenshot shows the Eramba web application interface, specifically the 'Compliance Package Items' section. The table displays items for 'Bahrain Personal Data Protection' (BHR-PDPL) and 'Cybersecurity Governance' (GDS-CY). The table has columns: Chapter ID, Chapter Name, Chapter Description, Item ID, Item Name, Item Description, and Item Additional Information. The items are grouped by chapter, with 'BHR-PDPL' and 'GDS-CY' visible. A 'Filter' button is present in the top right of the table area.

Figure 14: Sector-relevant compliance package items for government digital services and Bahrain privacy requirements.

Relevance: This proves that a second sector-relevant framework was created and mapped in addition to NIST CSF 2.0.

Dynamic Status	Item ID	Item Name	Item Description
☐	BHR-PDPL-01	Lawful Processing and D...	Personal data used
☐	GDS-CY-04	Cybersecurity Incident R...	Cybersecurity incic
☐	GDS-CY-03	Secure Email and Phishin...	Government email :
☐	GDS-CY-02	Critical Data Backup and ...	Critical governmen
☐	GDS-CY-01	Identity and Privileged A...	User access to sen

Figure 15: Compliance analysis list showing mapped requirements for the selected framework.

Relevance: This evidence confirms that compliance requirements were assessed and prepared for strategy, treatment, and risk mapping.

Dynamic Status	Data Assets	Asset	Asset Reviewer Contact	Enable GDPR Analysis?	Driver for Compliance	Data Owner	DPO Role	Processor Role
☐	1	Citizen Service Access L...	Citizen Services Mana...	Enabled	Citizen service access lo...	Citizen Services Mana...	Citizen Services Mana...	Security Monitoring An...
☐	1	Employee HR Records Sy...	Employee HR Records	Enabled	Employee HR records are...	Employee HR Records	Employee HR Records	Secure Cloud Backup P...
☐	1	Citizen Records Database	Citizen Services Mana...	Enabled	Citizen identity data is pr...	Citizen Services Mana...	Citizen Services Mana...	National Identity Verif...

Figure 16: Data processing activities showing GDPR analysis enabled, compliance drivers, data owners, DPO roles, and processor roles.

Relevance: This closes the processing activity requirement by showing that the privacy-focused data assets have GDPR analysis enabled and ownership assigned.

Processor Role	Controller Role	Controller Representative	Supervisory Authority
Security Monitoring Analytics	Citizen Services Mana...	Citizen Services Mana...	United Kingdom
Secure Cloud Backup Provider	Employee HR Records	Employee HR Records	United Kingdom
National Identity Verification	Citizen Services Mana...	Citizen Services Mana...	United Kingdom

Figure 17: Processing activity GDPR role mapping showing processor roles, controller representatives, and supervisory authority.

Relevance: This supports privacy accountability by documenting processor roles, controller representative fields, and the available supervisory authority option in Eramba.

Stage	Name	Business Units	Third Parties	Asset Risks	Third Party Risks	Business Risks	Improvement Projects	Compensating Controls	Policies
Transit	Citizen Access Log Monit...	Citizen Services Depart...	Security Monitoring Ar...	Unauthorized Access to Cit...	Privacy Exposure ?			Multi-Factor Authentication Co...	Identity Governance and Privileged Access Policy
Transit	Secure Cloud Backup Dat...	Human Resources Depar...	Secure Cloud Backup ?	Ransomware in HR Records ?				Backup and Recovery Control	Data Resilience and Recovery Policy
Transit	Citizen Identity Verificati...	Citizen Services Depart...	National Identity Verifi...	Unauthorized Access to Cit...				Multi-Factor Authentication Co...	Identity Governance and Privileged Access Policy

Figure 18: Data asset flows showing three privacy flows linked to business units, third parties, risks, controls, and policies.

Relevance: This proves the three-data-flow requirement and shows how privacy flows are linked to risk treatment and governance documents.

Reviews	Name	Next Review Date	Applicable Third Parties	Assets Shared with this Third Party	Risk Analysis Classification	Risk Analysis Score	Risk Tr
2	Privacy Exposure Throug...	2026-12-31	National Identity Verification Co...	Citizen Records Database	likelihood (Possible) Impact (Major)	12 High	Mitigatr

Risk Treatment	Treatment Risk Exceptions	Treatment Internal Controls	Treatment Projects	Treatment Policies	Risk Treatment Classification	Risk Treatment Score
Mitigate		Multi-Factor Authentication Co...		Identity Governance and Privi...	likelihood (Unlikely) Impact (Moderate)	6 Moderate

Figure 19: Third-party risk record showing treatment, internal control, policy linkage, and reduced residual score.

Relevance: This proves that third-party risk was assessed and treated through controls and policies, supporting the privacy and vendor-risk requirements.

Dynamic Status	Third Party Risks	Planned Date	Actual Date	Reviewers	Description
	Privacy Exposure Throug...	2026-12-31		Citizen Services Mana...	
	Privacy Exposure Throug...	2026-05-23	2026-05-23	Citizen Services Mana...	This Review was automatically created when the Risk item was created.

Figure 20: Third-party risk review records created for the privacy exposure risk.

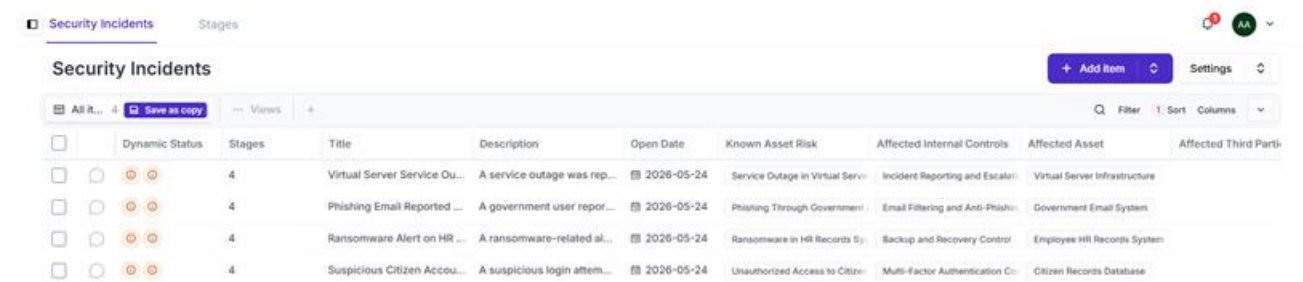
Relevance: This shows that third-party risk is not only created but also scheduled for governance review.

5.4 Student 4 - Integration, Incident and Reporting Lead

Student 4 completed the integration, incident, and reporting layer. Four incidents were created and linked to known asset risks, affected controls, and affected assets. Incident stages were added and applied to each incident. Improvement projects and tasks were also created to represent treatment plans for priority risks, and dashboard screenshots were captured to support final reporting.

Incident / Reporting Area	Implemented Items
Incidents	Suspicious citizen account access, ransomware alert on HR records, phishing email reported, virtual server service outage
Incident Linkage	Known asset risk, affected internal control, affected asset, owner, status, and open date
Lifecycle Stages	Identification, Containment, Investigation, Recovery and Closure

Improvement Projects	Citizen Access Control Improvement Project, HR Ransomware Recovery Improvement Project, Email Phishing Protection Improvement Project
Tasks	One task created per project with owner, deadline, order, and completion rate
Dashboard Evidence	Asset-based risk matrix and current compliance status

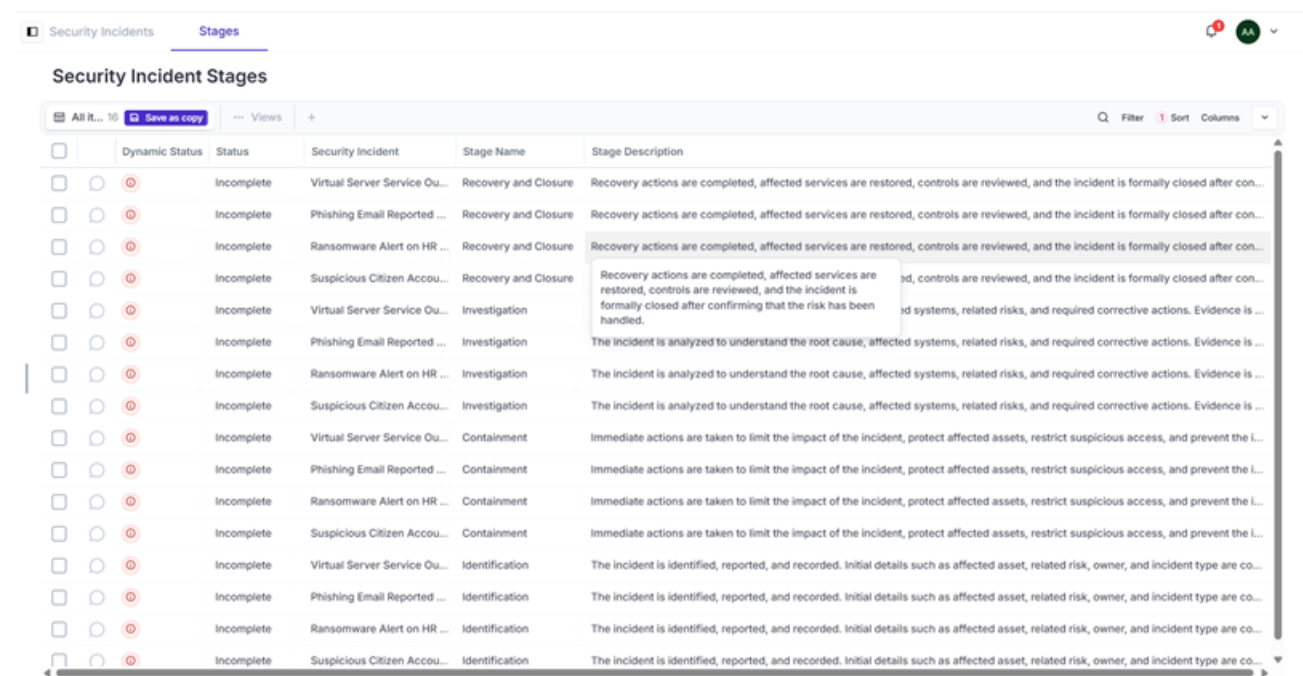


The screenshot shows a 'Security Incidents' dashboard with a table listing four incidents. Each incident is linked to specific asset risks, internal controls, and affected assets.

	Dynamic Status	Stages	Title	Description	Open Date	Known Asset Risk	Affected Internal Controls	Affected Asset	Affected Third Party
☐		4	Virtual Server Service Ou...	A service outage was rep...	2026-05-24	Service Outage in Virtual Serv...	Incident Reporting and Escalati...	Virtual Server Infrastructure	
☐		4	Phishing Email Reported ...	A government user repor...	2026-05-24	Phishing Through Governmen...	Email Filtering and Anti-Phishi...	Government Email System	
☐		4	Ransomware Alert on HR ...	A ransomware-related al...	2026-05-24	Ransomware in HR Records S...	Backup and Recovery Control	Employee HR Records System	
☐		4	Suspicious Citizen Accou...	A suspicious login attem...	2026-05-24	Unauthorized Access to Citizi...	Multi-Factor Authentication Co...	Citizen Records Database	

Figure 21: Security incidents list showing four incidents linked to asset risks, controls, and affected assets.

Relevance: This proves the incident management requirement and demonstrates that incidents were integrated with existing risk and control records.

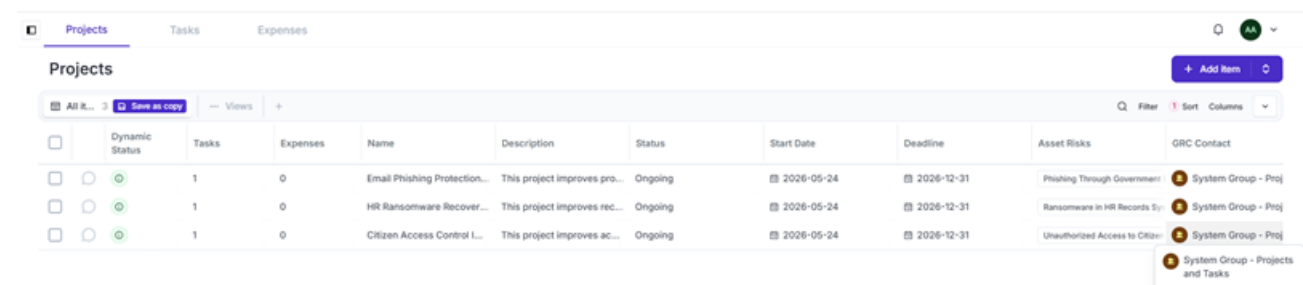


The screenshot shows a 'Security Incident Stages' dashboard with a table listing the lifecycle stages for the four incidents. The stages include Incomplete, Investigation, and Containment, each with a detailed description of the actions taken.

	Dynamic Status	Status	Security Incident	Stage Name	Stage Description
☐		Incomplete	Virtual Server Service Ou...	Recovery and Closure	Recovery actions are completed, affected services are restored, controls are reviewed, and the incident is formally closed after con...
☐		Incomplete	Phishing Email Reported ...	Recovery and Closure	Recovery actions are completed, affected services are restored, controls are reviewed, and the incident is formally closed after con...
☐		Incomplete	Ransomware Alert on HR ...	Recovery and Closure	Recovery actions are completed, affected services are restored, controls are reviewed, and the incident is formally closed after con...
☐		Incomplete	Suspicious Citizen Accou...	Recovery and Closure	Recovery actions are completed, affected services are restored, controls are reviewed, and the incident is formally closed after con...
☐		Incomplete	Virtual Server Service Ou...	Investigation	The incident is analyzed to understand the root cause, affected systems, related risks, and required corrective actions. Evidence is ...
☐		Incomplete	Phishing Email Reported ...	Investigation	The incident is analyzed to understand the root cause, affected systems, related risks, and required corrective actions. Evidence is ...
☐		Incomplete	Ransomware Alert on HR ...	Investigation	The incident is analyzed to understand the root cause, affected systems, related risks, and required corrective actions. Evidence is ...
☐		Incomplete	Suspicious Citizen Accou...	Investigation	The incident is analyzed to understand the root cause, affected systems, related risks, and required corrective actions. Evidence is ...
☐		Incomplete	Virtual Server Service Ou...	Containment	Immediate actions are taken to limit the impact of the incident, protect affected assets, restrict suspicious access, and prevent the l...
☐		Incomplete	Phishing Email Reported ...	Containment	Immediate actions are taken to limit the impact of the incident, protect affected assets, restrict suspicious access, and prevent the l...
☐		Incomplete	Ransomware Alert on HR ...	Containment	Immediate actions are taken to limit the impact of the incident, protect affected assets, restrict suspicious access, and prevent the l...
☐		Incomplete	Suspicious Citizen Accou...	Containment	Immediate actions are taken to limit the impact of the incident, protect affected assets, restrict suspicious access, and prevent the l...
☐		Incomplete	Virtual Server Service Ou...	Identification	The incident is identified, reported, and recorded. Initial details such as affected asset, related risk, owner, and incident type are co...
☐		Incomplete	Phishing Email Reported ...	Identification	The incident is identified, reported, and recorded. Initial details such as affected asset, related risk, owner, and incident type are co...
☐		Incomplete	Ransomware Alert on HR ...	Identification	The incident is identified, reported, and recorded. Initial details such as affected asset, related risk, owner, and incident type are co...
☐		Incomplete	Suspicious Citizen Accou...	Identification	The incident is identified, reported, and recorded. Initial details such as affected asset, related risk, owner, and incident type are co...

Figure 22: Incident lifecycle stages applied across security incidents.

Relevance: This shows that incidents were managed through a defined lifecycle, including identification, containment, investigation, and recovery/closure.



The screenshot shows a 'Projects' dashboard with a table listing three improvement projects. Each project is linked to specific asset risks and has a defined status, start date, and deadline.

	Dynamic Status	Tasks	Expenses	Name	Description	Status	Start Date	Deadline	Asset Risks	GRC Contact
☐		1	0	Email Phishing Protection...	This project improves pro...	Ongoing	2026-05-24	2026-12-31	Phishing Through Governmen...	System Group - Proj
☐		1	0	HR Ransomware Recover...	This project improves rec...	Ongoing	2026-05-24	2026-12-31	Ransomware in HR Records S...	System Group - Proj
☐		1	0	Citizen Access Control L...	This project improves ac...	Ongoing	2026-05-24	2026-12-31	Unauthorized Access to Citizi...	System Group - Proj

Figure 23: Improvement projects linked to priority asset risks with status, dates, and GRC ownership.

Relevance: This proves that three risk treatment projects were created and connected to priority risks.

Dynamic Status	Task Owner	Completion Rate	Deadline	Task Order	Description	Project	Project Owner	Project Description	Project Start Date	Project Deadline	Project Status
	Email Systems Admin	30	2026-12-31	1	Review email filtering rules	Email Phishing Protection L...	Email Systems Admin	This project im...	2026-05-24	2026-12-31	Ongoing
	Employee HR Records	40	2026-12-31	1	Verify that HR system ba...	HR Ransomware Recovery L...	Employee HR Records	This project im...	2026-05-24	2026-12-31	Ongoing
	Citizen Services Mana	50	2026-12-31	1	Review user permissions ...	Citizen Access Control Impr...	Citizen Services Mana	This project im...	2026-05-24	2026-12-31	Ongoing

Figure 24: Project tasks showing owners, completion rates, deadlines, and project linkage.

Relevance: This shows that improvement projects have actionable tasks and measurable progress rather than being empty project records.



Figure 25: Dashboard current compliance status for NIST CSF 2.0, Bahrain privacy, and government digital services compliance packages.

Relevance: This proves the compliance dashboard widget requirement and shows monitoring of the implemented compliance packages.

5.5 Additional Cross-Module Evidence

The following updated screenshots were added to strengthen the final report evidence. They provide clearer proof of review cycles, cross-module linkages, compliance package ownership, and detailed compliance mapping across NIST CSF 2.0, government digital services, and Bahrain privacy requirements.

Dynamic Status	Asset Risks	Planned Date	Actual Date	Reviewers	Description
	Service Outage in Virtual ...	2026-12-31		Infrastructure Adminis...	
	Service Outage in Virtual ...	2026-05-23	2026-05-23	Infrastructure Adminis...	This Review was automatically created when the Ri...
	Loss of Official Documents	2026-12-31		Records Management	
	Loss of Official Documents	2026-05-23	2026-05-23	Records Management	This Review was automatically created when the Ri...
	Phishing Through Govern...	2026-12-31		Email Systems Adminis...	
	Phishing Through Govern...	2026-05-23	2026-05-23	Email Systems Adminis...	This Review was automatically created when the Ri...
	Ransomware in HR Recor...	2026-12-31		Employee HR Records	
	Ransomware in HR Recor...	2026-05-23	2026-05-23	Employee HR Records	This Review was automatically created when the Ri...
	Unauthorized Access to ...	2026-12-31		Citizen Services Mana	
	Unauthorized Access to ...	2026-05-23	2026-05-23	Citizen Services Mana	This Review was automatically created when the Ri...

Figure 26: Asset risk review records showing planned and completed review dates for priority risks.

Relevance: This strengthens Student 1 evidence by showing that the asset risks were not only created, but also placed into a governance review cycle with assigned reviewers and planned review dates.

	Policy	Document Type	Compliance Package	Asset Risks Treatment	Third Party Risks Treatment	Data Asset Flow	Internal Controls	Relationship
☐	☐	Policy	Government Digital Services C...	Service Outage in Virtual Serv...			Incident Reporting and Escala...	
☐	☐	Policy	Government Digital Services C...	Phishing Through Governmen...			Email Filtering and Anti-Phish...	
☐	☐	Policy	Government Digital Services C...	Ransomware in HR Records Sy...		Secure Cloud Backup Data Flo...	Backup and Recovery Control...	
☐	☐	Policy	Government Digital Services C...	Unauthorized Access to Citiz...	Privacy Exposure Through Ide...	Citizen Identity Verification Du...	Multi-Factor Authentication Co...	

Figure 27: Policy library cross-module linkage view showing policies connected to compliance packages, risk treatments, data asset flows, and internal controls.

Relevance: This strengthens Student 2 evidence by proving that policies are linked to risks, controls, compliance packages, and privacy data flows instead of remaining standalone documents.

	Dynamic Status	Compliance Package Items	Name	Description	GRC Contact
☐	☐	134	NIST Cybersecurity Fram...	This compliance package...	System Group - View Policies and Reviews
☐	☐	1	Bahrain Personal Data Pr...	This compliance package...	System Group - View Policies and Reviews
☐	☐	4	Government Digital Servi...	This compliance package...	System Group - View Policies and Reviews

Figure 28: Compliance packages overview showing NIST CSF 2.0, Bahrain privacy, and government digital services packages with item counts and GRC contact ownership.

Relevance: This strengthens Student 3 evidence by clearly showing the required NIST CSF 2.0 framework and additional sector-relevant compliance packages in the compliance module.

	Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	☐	GDS-CY-04	Cybersecurity Incident R...	Cybersecurity incidents ...	Compliant	Incident Reporting and Escala...	Incident Response Policy
☐	☐	GDS-CY-03	Secure Email and Phishin...	Government email servic...	Compliant	Email Filtering and Anti-Phish...	Email Security Policy
☐	☐	GDS-CY-02	Critical Data Backup and ...	Critical government syst...	Compliant	Backup and Recovery Control...	Data Resilience and Recovery ...
☐	☐	GDS-CY-01	Identity and Privileged A...	User access to sensitive ...	Compliant	Multi-Factor Authentication Co...	Identity Governance and Privi...

Figure 29: Government digital services compliance analysis showing four sector requirements marked as compliant and mapped to supporting controls and policies.

Relevance: This proves that sector-specific compliance requirements were mapped to real Eramba treatment evidence, including internal controls and policies.

	Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	☐	BHR-PDPL-01	Lawful Processing and D...	Personal data used by go...	Compliant	Multi-Factor Authentication Co...	Identity Governance and Privi...

Figure 30: Bahrain personal data protection compliance analysis showing the lawful processing requirement marked as compliant and mapped to access control evidence.

Relevance: This supports the privacy and regulatory context by showing that the Bahrain privacy requirement was assessed and mapped to the identity governance policy and MFA control.

Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	GV.RM-05	Lines of communication ...	Lines of communication ...			
☐	GV.RM-04	Strategic direction that d...	Strategic direction that d...			
☐	GV.RM-03	Cybersecurity risk mana...	Cybersecurity risk mana...			
☐	GV.RM-02	Risk appetite and risk tol...	Risk appetite and risk tol...	Compliant	Backup and Recovery Control	Data Resilience and Rec
☐	GV.RM-01	Risk management objecti...	Risk management objecti...			
☐	GV.RM	The organization's priori...	The organization's priori...			
☐	GV.OC-05	Outcomes, capabilities, a...	Outcomes, capabilities, a...			
☐	GV.OC-04	Critical objectives, capab...	Critical objectives, capab...			
☐	GV.OC-03	Legal, regulatory, and co...	Legal, regulatory, and co...	Compliant	Multi-Factor Authentication Co	Identity Governance and
☐	GV.OC-02	Internal and external stak...	Internal and external stak...			
☐	GV.OC-01	The organizational missio...	The organizational missio...			
☐	GV.OC	The circumstances - mis...	The circumstances - mis...			
☐	GV	The organization's cyber...	The organization's cyber...			

Figure 31: NIST CSF 2.0 compliance analysis showing governance requirements mapped to controls and policies.

Relevance: This strengthens the compliance mapping evidence by showing NIST governance requirements with compliant strategy values and supporting treatment links.

Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	ID.AM-08	Systems, hardware, soft...	Systems, hardware, soft...			
☐	ID.AM-07	Inventories of data and c...	Inventories of data and c...			
☐	ID.AM-05	Assets are prioritized bas...	Assets are prioritized bas...			
☐	ID.AM-04	Inventories of services pr...	Inventories of services pr...			
☐	ID.AM-03	Representations of the or...	Representations of the or...			
☐	ID.AM-02	Inventories of software, s...	Inventories of software, s...			
☐	ID.AM-01	Inventories of hardware ...	Inventories of hardware ...	Compliant	Backup and Recovery Control	Data Resilience and Rec
☐	ID.AM	Assets (e.g., data, hardw...	Assets (e.g., data, hardw...			
☐	ID	The organization's curren...	The organization's curren...			
☐	GV.SC-10	Cybersecurity supply ch...	Cybersecurity supply ch...			
☐	GV.SC-09	Supply chain security pra...	Supply chain security pra...			
☐	GV.SC-08	Relevant suppliers and ot...	Relevant suppliers and ot...			
☐	GV.SC-07	The risks posed by a sup...	The risks posed by a sup...			
☐	GV.SC-06	Planning and due diligen...	Planning and due diligen...			

Figure 32: NIST CSF 2.0 asset management requirement mapping linked to backup and recovery treatment evidence.

Relevance: This shows that asset inventory and recovery-related requirements were connected to the Backup and Recovery Control and Data Resilience and Recovery Policy.

Compliance Analysis

Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	PR.AA-04	Identity assertions are pr...	Identity assertions are pr...			
☐	PR.AA-03	Users, services, and hard...	Users, services, and hard...			
☐	PR.AA-02	Identities are proofed an...	Identities are proofed an...			
☐	PR.AA-01	Identities and credentials...	Identities and credentials...	Compliant	Multi-Factor Authentication Co...	Identity Governance and
☐	PR.AA	Access to physical and lo...	Access to physical and lo...			
☐	PR	Safeguards to manage th...	Safeguards to manage th...			
☐	ID.IM-04	Incident response plans ...	Incident response plans ...			
☐	ID.IM-03	Improvements are identifi...	Improvements are identifi...			
☐	ID.IM-02	Improvements are identifi...	Improvements are identifi...			
☐	ID.IM-01	Improvements are identifi...	Improvements are identifi...			
☐	ID.IM	Improvements to organiz...	Improvements to organiz...			
☐	ID.RA-10	Critical suppliers are ass...	Critical suppliers are ass...			
☐	ID.RA-09	The authenticity and inte...	The authenticity and inte...			

Figure 33: NIST CSF 2.0 identity and access requirement mapping linked to MFA and identity governance evidence.

Relevance: This directly supports the access control compliance requirement by showing PR.AA-01 marked compliant and mapped to the Multi-Factor Authentication Control and Identity Governance policy.

Compliance Analysis

Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy	Internal Controls	Policies
☐	RS.MA-02	Incident reports are triag...	Incident reports are triag...			
☐	RS.MA-01	The incident response pl...	The incident response pl...	Compliant	Incident Reporting and Escalati...	Incident Response Policy
☐	RS.MA	Responses to detected c...	Responses to detected c...			
☐	RS	Actions regarding a dete...	Actions regarding a dete...			
☐	DE.AE-08	Incidents are declared w...	Incidents are declared w...			
☐	DE.AE-07	Cyber threat intelligence ...	Cyber threat intelligence ...			
☐	DE.AE-06	Information on adverse e...	Information on adverse e...			
☐	DE.AE-04	The estimated impact an...	The estimated impact an...			
☐	DE.AE-03	Information is correlated ...	Information is correlated ...			
☐	DE.AE-02	Potentially adverse event...	Potentially adverse event...			
☐	DE.AE	Anomalies, indicators of ...	Anomalies, indicators of ...			
☐	DE.CM-09	Computing hardware and...	Computing hardware and...	Compliant	Email Filtering and Anti-Phishin...	Email Security Policy
☐	DE.CM-06	External service provider ...	External service provider ...			

Figure 34: NIST CSF 2.0 detection and response mappings linked to incident reporting and email security controls.

Relevance: This confirms that response and monitoring requirements were mapped to the Incident Reporting and Escalation Control, Incident Response Policy, Email Filtering control, and Email Security Policy.

6. Analysis and Discussion

6.1 Top Risk Interpretation

In the Risk Matrix, it is evident that there were some risks that were initially classified as High and Severe risks. Some of the risks include the risk of access to citizens' data without authorization and risks related to HR data and governmental services. In the treatment indicators, it is evident that the residual risks have been reduced through mitigation strategies.

Priority Risk	Main Impact	Treatment Approach
---------------	-------------	--------------------

Unauthorized Access to Citizen Records	Privacy breach, identity misuse, legal/regulatory impact	MFA Control, Identity Governance Policy, access control improvement project
Ransomware in HR Records System	Loss of employee records, service disruption, recovery cost	Backup and Recovery Control, Data Resilience Policy, ransomware recovery project
Phishing Through Government Email System	Credential compromise and unauthorized access	Email Filtering Control, Email Security Policy, phishing protection project
Service Outage in Virtual Server Infrastructure	Availability impact to government digital services	Incident Reporting and Escalation Control, Incident Response Policy

6.2 Compliance and Privacy Interpretation

The evidence for compliance includes mapping NIST CSF 2.0 and governmental/privacy compliance requirements. The extra compliance screenshots further substantiate this evidence through providing several mappings for governmental digital service compliance, Bahrain privacy compliance, and NIST CSF 2.0, including control and policy treatments. The reason this is critical is that the auditors require an ability to map the requirements to evidence of governance provided by the organization. Privacy-related evidence suggests that the organization has determined types of personal information processed; purpose, use, owner, data processors; and relevant control and policy treatments of data flows.

6.3 Incident and Improvement Interpretation

Incidents records have shown that there is an integration of the security operation with the GRC system where each incident has some relationship with certain risks and assets or controls involved. The improvements are carried out through risk treatment to improve remediation activities. They involve having owners, deadlines, and progress rates towards completion.

7. Conclusion and Recommendations

The Eramba implementation successfully demonstrates a complete GRC system for a government digital services organization. The system documents business units, assets, risk classifications, risks, policies, controls, audits, maintenances, compliance frameworks, privacy records, third parties, data flows, incidents, projects, and dashboard reporting. The evidence shows that the required modules were implemented and that the records are connected across Eramba modules.

Recommendations

- Complete periodic review cycles for all policies, controls, risks, and privacy records before each audit period.
- Use the dashboard regularly to monitor high and severe risks and verify that treatment projects are reducing residual exposure.
- Continue expanding compliance mapping beyond the minimum five requirements so management can see broader framework coverage.
- Test incident response stages using tabletop exercises and record the outcome in Eramba as evidence.
- Review third-party contracts and ensure processors support reporting, privacy requests, and secure data handling requirements.

In general, this implementation proves that Eramba is capable of integrating the various functions such as governance, risk management, compliance analysis, privacy management, and incident response all into one trackable system.

8. Workload Contribution Table

Student	Role	Assigned Workload	Completed Workload	Main Tasks Completed	Peer Review Remarks
Student 1: Abdulrahman Altairey	Asset and Risk Lead	25%	100%	Business units, assets, liabilities, risk scoring, appetite matrix, asset risk register	Completed assigned tasks and evidence.

Student 2: Abdulelah Slais	Policy and Control Lead	25%	100%	Policies, versions/reviews, internal controls, audits, maintenances, risk-control- policy linkage	Completed assigned tasks and evidence.
Student 3: khalid Alhariri	Compliance and Privacy Lead	25%	100%	NIST import, additional framework, compliance mappings, privacy data assets, processing activities, third parties, data flows	Completed assigned tasks and evidence.
Student 4: Abdullah Hoth	Integration, Incident and Reporting Lead	25%	100%	Incidents, incident stages, improvement projects, project tasks, dashboard screenshots, evidence organization	Completed assigned tasks and final integration.

9. References

Bahrain Polytechnic. (2026). *IT8515 course project brief: Real-time GRC system design and implementation using Eramba platform*.

Bahrain Polytechnic. (2026). *Week 7 lab: Asset and risk — Identifying and creating risks in Eramba*.

Bahrain Polytechnic. (2026). *Week 8 lab: Policies — Creating and managing policies in Eramba*.

Bahrain Polytechnic. (2026). *Week 9 lab — Part 1: Mapping controls in Eramba*.

Bahrain Polytechnic. (2026). *Week 9 lab — Part 2: Performing compliance analysis in Eramba*.

Bahrain Polytechnic. (2026). *Week 10 lab: Data privacy — Managing data privacy using Eramba*.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>

Kingdom of Bahrain. (2018). *Law No. 30 of 2018 with respect to Personal Data Protection Law*. Personal Data Protection Authority. <https://www.pdp.gov.bh/>

Eramba. (n.d.). *Eramba GRC platform documentation*. Retrieved May 24, 2026, from <https://www.eramba.org/>

Appendix A - Evidence Index

Figure	Section	Evidence Description
Figure 1	Student 1	Business units configured in Eramba for the government digital services organization.
Figure 2	Student 1	Asset liability and classification drivers configured in Eramba.
Figure 3	Student 1	Asset inventory showing critical systems, business units, owners, review dates, and potential liabilities.
Figure 4	Student 1	Risk calculation method configured as Single Matrix - Multiplication.
Figure 5	Student 1 / Student 4	Dashboard asset-based risk matrix showing analysis and treatment stage risk positions.
Figure 6	Student 1	Asset risk register showing five risks linked to assets, scores, treatment, and residual scores.
Figure 7	Student 1 / Student 4	Risk treatment view showing internal controls, policies, projects, and residual treatment classifications.
Figure 8	Student 2	Policy library showing four published policies with review counts and next review dates.
Figure 9	Student 2	Policy review records showing version and planned review evidence for the created policies.
Figure 10	Student 2	Internal controls list showing four controls with audit counts, maintenance counts, related policies, and linked risks.
Figure 11	Student 2	Internal control audit records created for the implemented controls.
Figure 12	Student 2	Internal control maintenance records showing planned maintenance activities for controls.

Figure 13	Student 3	NIST Cybersecurity Framework 2.0 compliance package imported with 134 requirement items.
Figure 14	Student 3	Sector-relevant compliance package items for government digital services and Bahrain privacy requirements.
Figure 15	Student 3	Compliance analysis list showing mapped requirements for the selected framework.
Figure 16	Student 3	Data processing activities showing GDPR analysis enabled, compliance drivers, data owners, DPO roles, and processor roles.
Figure 17	Student 3	Processing activity GDPR role mapping showing processor roles, controller representatives, and supervisory authority.
Figure 18	Student 3	Data asset flows showing three privacy flows linked to business units, third parties, risks, controls, and policies.
Figure 19	Student 3	Third-party risk record showing treatment, internal control, policy linkage, and reduced residual score.
Figure 20	Student 3	Third-party risk review records created for the privacy exposure risk.
Figure 21	Student 4	Security incidents list showing four incidents linked to asset risks, controls, and affected assets.
Figure 22	Student 4	Incident lifecycle stages applied across security incidents.
Figure 23	Student 4	Improvement projects linked to priority asset risks with status, dates, and GRC ownership.
Figure 24	Student 4	Project tasks showing owners, completion rates, deadlines, and project linkage.
Figure 25	Student 4	Dashboard current compliance status for NIST CSF 2.0, Bahrain privacy, and government digital services compliance packages.
Figure 26	Student 1	Asset risk review records showing planned and completed risk reviews for priority risks.
Figure 27	Student 2	Policy cross-module linkage showing policy relationships with risks, compliance packages, data flows, and internal controls.
Figure 28	Student 3	Compliance package overview showing NIST CSF 2.0, Bahrain privacy, and government digital services compliance packages.
Figure 29	Student 3	Government digital services compliance analysis showing mapped controls and policies.
Figure 30	Student 3	Bahrain privacy compliance analysis showing lawful processing mapped to treatment evidence.
Figure 31	Student 3	NIST CSF governance requirement mappings linked to controls and policies.
Figure 32	Student 3	NIST CSF asset management mapping linked to backup and data resilience treatment evidence.
Figure 33	Student 3	NIST CSF identity and access mapping linked to MFA and identity governance evidence.
Figure 34	Student 3	NIST CSF detection and response mappings linked to incident response and email security controls.

Appendix B - Final Readiness Checklist

Checklist Item	Status
All minimum Eramba modules implemented	Completed
Each screenshot has a figure number and caption	Completed
Each screenshot has a relevance explanation	Completed
Workload contribution table included	Completed
References included	Completed
Student names/IDs completed and reviewed by group before submission	Completed
Additional compliance mapping screenshots included	Completed